



**INSTITUTO TECNOLÓGICO Y DE ESTUDIOS SUPERIORES DE MONTERREY**

Escuela de Ingeniería y Ciencias  
Ingeniería en Ciencia de Datos y Matemáticas

## **GESTOR DE IDENTIDADES V1.0**

*Manual de Usuario*

**Socio Formador: Casa Monarca**

**Equipo de trabajo: 1 | Grupo: 603**

**Integrantes:**

Miranda Cornejo Ahuja — A01571668  
Natalia Cervantes González — A00838465  
Hugo Jaime Valdés — A01384039  
Jorge Alfonso Andujo Valdéz — A01563535  
Ana Sofía Ibarra Ponce — A01285836

**Profesores:**

Raúl Gómez, Anas Wajid y Alberto F. Martínez

Monterrey, Nuevo León  
30 de abril de 2026

## Índice de Contenidos

|                                                          |    |
|----------------------------------------------------------|----|
| Introducción .....                                       | 3  |
| ¿Qué es la aplicación? .....                             | 3  |
| ¿Para qué sirve? .....                                   | 3  |
| ¿A quién va dirigida? .....                              | 3  |
| Requerimientos del Sistema .....                         | 4  |
| Hardware mínimo .....                                    | 4  |
| Software necesario .....                                 | 4  |
| Para usuario final (solo acceso vía navegador): .....    | 4  |
| Para instalación local (administradores técnicos): ..... | 4  |
| Versiones compatibles .....                              | 5  |
| Instalación .....                                        | 6  |
| Consideraciones previas .....                            | 6  |
| Instalación del Backend .....                            | 6  |
| Instalación del Frontend .....                           | 6  |
| Variables de entorno principales .....                   | 7  |
| Puertos y URLs del sistema .....                         | 7  |
| Inicio de la Aplicación .....                            | 9  |
| Cómo acceder .....                                       | 9  |
| Inicio de sesión — Doble factor obligatorio .....        | 9  |
| Paso 1 — Ingresar credenciales .....                     | 9  |
| Paso 2 — Verificación con código TOTP .....              | 9  |
| Configuración inicial — Enrolamiento TOTP .....          | 9  |
| Activación de cuenta nueva .....                         | 9  |
| Guía de Uso .....                                        | 10 |
| Panel de administración .....                            | 10 |
| Registrar un nuevo colaborador .....                     | 10 |
| Paso a paso: .....                                       | 10 |
| Resultado esperado: .....                                | 10 |
| Registrar una persona migrante .....                     | 10 |
| Paso a paso: .....                                       | 10 |
| Resultado esperado: .....                                | 10 |
| Consultar la bitácora de auditoría .....                 | 10 |
| Paso a paso: .....                                       | 11 |
| Resultado esperado: .....                                | 11 |
| Gestionar el estado de un colaborador .....              | 11 |
| Solución de Problemas .....                              | 12 |
| Errores comunes y soluciones .....                       | 12 |
| ¿Qué hacer si algo falla inesperadamente? .....          | 12 |
| Preguntas Frecuentes (FAQ) .....                         | 12 |

## Introducción

### ¿Qué es la aplicación?

El Gestor de Identidades V1.0 (Casa Monarca — Identity Access Manager) es una aplicación web desarrollada para gestionar de forma segura las identidades digitales de los colaboradores de Casa Monarca, organización sin fines de lucro que atiende a población migrante vulnerable. El sistema centraliza el ciclo de vida de cada usuario —alta, activación, autenticación, revocación y auditoría— usando criptografía de clave pública (RSA-2048 y ECDSA P-256), autenticación de doble factor y control de acceso basado en roles (RBAC).

### ¿Para qué sirve?

La aplicación permite a la organización:

- Registrar colaboradores con identidades digitales institucionales respaldadas por certificados internos.
- Controlar quién accede a qué información según su rol y nivel de responsabilidad.
- Registrar personas migrantes con integridad criptográfica (hash SHA-256) y cifrado de campos sensibles.
- Firmar documentos digitalmente con certificados ECDSA P-256 (flujo similar al SAT).
- Mantener una bitácora inmutable de todas las acciones críticas para garantizar trazabilidad.

### ¿A quién va dirigida?

Este manual está dirigido al personal de Casa Monarca sin necesidad de conocimientos técnicos avanzados. La siguiente tabla resume los cuatro niveles de usuario:

| Nivel | Rol                                      | Permisos principales                                                                   |
|-------|------------------------------------------|----------------------------------------------------------------------------------------|
| 1     | Administrador del Sistema                | Acceso completo: gestión de usuarios, bitácora, plantillas y eliminación de registros. |
| 2     | Coordinador de Área                      | Crear, leer y editar registros. Sin eliminar ni gestionar usuarios.                    |
| 3     | Personal Operativo                       | Crear y leer registros. Sin editar ni eliminar.                                        |
| 4     | Personal Externo (becarios, voluntarios) | Solo crear registros. Sin lectura de registros internos.                               |

## Requerimientos del Sistema

### Hardware mínimo

| Componente      | Mínimo recomendado                                                  |
|-----------------|---------------------------------------------------------------------|
| Procesador      | Intel Core i3 / AMD Ryzen 3 (o equivalente) — 2.0 GHz               |
| Memoria RAM     | 4 GB (8 GB recomendado para ejecutar backend + frontend localmente) |
| Almacenamiento  | 2 GB libres en disco (adicionales para base de datos en producción) |
| Conexión de red | Requerida para acceso al sistema desplegado; 10 Mbps o superior     |

### Software necesario

Para usuario final (solo acceso vía navegador):

| Software        | Versión mínima | Notas                                                 |
|-----------------|----------------|-------------------------------------------------------|
| Google Chrome   | 110+           | Recomendado (compatibilidad total con Web Crypto API) |
| Mozilla Firefox | 115+           | Compatible                                            |
| Microsoft Edge  | 110+           | Compatible                                            |
| Safari          | 16+            | Compatible con limitaciones menores                   |

Para instalación local (administradores técnicos):

| Software | Versión            | Propósito                              |
|----------|--------------------|----------------------------------------|
| Python   | 3.9 o superior     | Ejecución del backend FastAPI          |
| Node.js  | 18 o superior      | Build del frontend React/Vite          |
| MySQL    | 8.0 (producción)   | Base de datos en entorno productivo    |
| SQLite   | Incluido en Python | Base de datos en entorno de desarrollo |

## Versiones compatibles

| Librería / Framework  | Versión  |
|-----------------------|----------|
| FastAPI               | 0.110.0  |
| React                 | 18.2.0   |
| SQLAlchemy            | 2.0.29   |
| cryptography (Python) | ≥ 42.0.0 |
| Vite                  | 5.2.11   |
| pyotp                 | 2.9.0    |

## Instalación

### Consideraciones previas

Antes de instalar el sistema, tenga en cuenta los siguientes puntos:

- El sistema consta de dos partes independientes: un backend (Python/FastAPI) y un frontend (React/Vite). Ambos deben ejecutarse simultáneamente.
- Para entorno de desarrollo se utiliza SQLite, que no requiere instalación adicional. Para producción se requiere MySQL 8.0.
- El proyecto no incluye Docker. La instalación se realiza directamente sobre el sistema operativo.
- En modo demo (sin SMTP configurado), los enlaces de activación se almacenan en memoria y se consultan desde el panel de administración.

### Instalación del Backend

Ejecute los siguientes pasos en orden desde la terminal:

1. Ubíquese en la carpeta del backend:

```
cd backend
```

2. Cree y active el entorno virtual de Python:

```
python -m venv .venv
.venv\Scripts\activate      # Windows
source .venv/bin/activate   # Linux / macOS
```

3. Instale las dependencias:

```
pip install -r requirements.txt
```

4. Configure las variables de entorno:

```
copy .env.example .env      # Windows
cp .env.example .env         # Linux / macOS
```

5. Edite el archivo .env con los parámetros de su entorno (ver sección Versiones Compatibles).

6. Aplique las migraciones de base de datos:

```
alembic upgrade head
```

7. Ejecute el seed inicial para crear roles, áreas y usuario administrador:

```
python -m scripts.seed_initial_data
```

8. Inicie el servidor:

```
uvicorn app.main:app --reload --host 0.0.0.0 --port 8000
```

**Verificación:** Abra su navegador y acceda a <http://localhost:8000/health>. Debe recibir la respuesta `{"status": "ok"}`.

### Instalación del Frontend

1. Ubíquese en la carpeta del frontend:

```
cd frontend
```

2. Instale las dependencias de Node.js:

```
npm install
```

## 3. Configure la URL del backend:

```
copy .env.example .env      # Windows
cp .env.example .env        # Linux / macOS
```

Edite el archivo `.env` y asegúrese de que contenga:

```
VITE_API_URL=http://localhost:8000/api/v1
```

## 4. Inicie el servidor de desarrollo:

```
npm run dev
```

**Verificación:** Abra su navegador y acceda a `http://localhost:5173`. Debe visualizar la pantalla de inicio de sesión del sistema.

## Variables de entorno principales

| Variable             | Descripción                                                      | Ejemplo / Valor por defecto                                           |
|----------------------|------------------------------------------------------------------|-----------------------------------------------------------------------|
| SECRET_KEY           | Clave secreta para firmar JWT. Debe ser aleatoria en producción. | <code>python -c "import secrets; print(secrets.token_hex(32))"</code> |
| SQLITE_PATH          | Ruta de la base de datos SQLite (solo desarrollo).               | <code>./app.db</code>                                                 |
| DATABASE_URL         | URL de conexión MySQL (producción).                              | <code>mysql+pymysql://user:pass@host:3306/db</code>                   |
| SMTP_HOST            | Servidor de correo saliente. Vacío = modo demo activo.           | <code>smtp.gmail.com</code>                                           |
| FIELD_ENCRYPTION_KEY | Clave Fernet para cifrar campos sensibles.                       | <code>Fernet.generate_key().decode()</code>                           |
| ADMIN_EMAIL          | Correo del administrador creado en el seed.                      | <code>admin@demo.org</code>                                           |
| ADMIN_PASSWORD       | Contraseña del administrador creado en el seed.                  | <code>Admin123!</code>                                                |
| CORS_ORIGINS         | Orígenes permitidos para el frontend.                            | <code>http://localhost:5173</code>                                    |

## Puertos y URLs del sistema

| Servicio              | Puerto | URL local                                |
|-----------------------|--------|------------------------------------------|
| Frontend (desarrollo) | 5173   | <code>http://localhost:5173</code>       |
| Backend API           | 8000   | <code>http://localhost:8000</code>       |
| Documentación Swagger | 8000   | <code>http://localhost:8000/docs</code>  |
| Documentación ReDoc   | 8000   | <code>http://localhost:8000/redoc</code> |

|              |      |                                                                         |
|--------------|------|-------------------------------------------------------------------------|
| Health check | 8000 | <a href="http://localhost:8000/health">http://localhost:8000/health</a> |
|--------------|------|-------------------------------------------------------------------------|



## Inicio de la Aplicación

### Cómo acceder

Una vez que backend y frontend estén en ejecución, abra su navegador web preferido (Chrome o Firefox recomendado) e ingrese la dirección del sistema. En entorno local es `http://localhost:5173`. Si el sistema está desplegado en un servidor, utilice la URL que le haya proporcionado el administrador técnico.

### Inicio de sesión — Doble factor obligatorio

El sistema requiere dos pasos para autenticarse. Este mecanismo de doble factor (2FA) protege la cuenta incluso si alguien conoce su contraseña.

#### Paso 1 — Ingresar credenciales

1. En la pantalla de inicio, ingrese su correo electrónico y contraseña.
2. Haga clic en el botón **Iniciar sesión**.
3. El sistema validará sus credenciales y, si son correctas, le solicitará el segundo factor.

#### Paso 2 — Verificación con código TOTP

1. Abra su aplicación autenticadora (Google Authenticator, Microsoft Authenticator o similar).
2. Localice la cuenta “Casa Monarca” y obtenga el código de 6 dígitos vigente.
3. Ingrese el código en el campo de verificación y haga clic en **Verificar código**.
4. Los códigos TOTP cambian cada 30 segundos. Si el código no funciona, espere al siguiente.

### Configuración inicial — Enrolamiento TOTP

Si es la primera vez que accede, deberá enrollar su dispositivo como segundo factor. El sistema le presentará un código QR:

1. Abra su aplicación autenticadora en el teléfono.
2. Seleccione la opción **Agregar cuenta** o **Escanear código QR**.
3. Escanee el código QR que muestra el sistema.
4. Ingrese el código de 6 dígitos que genera la app para confirmar el enrolamiento.

Una vez completado, su dispositivo quedará vinculado a su cuenta y el sistema le solicitará el código en cada inicio de sesión.

### Activación de cuenta nueva

Si el administrador le registró como nuevo colaborador, recibirá un correo con un enlace de activación con vigencia de 48 horas. Siga estos pasos:

1. Haga clic en el enlace de activación del correo.
2. El sistema le pedirá que establezca una contraseña segura para su cuenta.
3. Defina una contraseña con mínimo 8 caracteres, combinando mayúsculas, minúsculas y números.
4. Complete el enrolamiento TOTP (ver sección 4.3).
5. Su cuenta quedará activada y podrá iniciar sesión normalmente.

**Nota:** Si el enlace expiró (más de 48 horas), contacte al administrador para que genere un nuevo registro.

## Guía de Uso

### Panel de administración

Una vez autenticado, el sistema muestra el Dashboard principal con acceso a los módulos según su rol. Los administradores (Nivel 1) ven todos los módulos disponibles; los demás roles ven únicamente las secciones a las que tienen acceso.

### Registrar un nuevo colaborador

*Disponible solo para Administradores del Sistema (Nivel 1).*

#### Paso a paso:

1. En el menú lateral, navegue a **Usuarios**.
2. Haga clic en **Nuevo Usuario**.
3. Complete el formulario con los siguientes datos:
  - Nombre completo del colaborador.
  - Correo (debe ser único en el sistema).
  - Área a la que pertenece.
  - Nivel de acceso (1–4) y rol correspondiente.
  - Fecha de inicio y fecha de expiración de la vigencia.
4. Haga clic en **Registrar**. El sistema validará que el correo no esté duplicado.
5. Al registrar correctamente, el sistema:
  - Crea el usuario con estado PENDIENTE.
  - Genera automáticamente un certificado de identidad RSA-2048.
  - Genera un token de activación con vigencia de 48 horas.
  - Envía el enlace de activación por correo (o lo almacena en modo demo).

#### Resultado esperado:

El colaborador aparece en la lista con estado PENDIENTE. Una vez que active su cuenta, el estado cambia a ACTIVO.

### Registrar una persona migrante

*Disponible para todos los niveles (1, 2, 3 y 4).*

#### Paso a paso:

1. Navegue a **Nuevo Registro**.
2. Complete el formulario:
  - Nombre o alias (se almacena cifrado para proteger la identidad).
  - Nacionalidad, idioma, rango de edad y género.
  - Información de contacto.
  - Necesidades detectadas (alimentación, alojamiento, orientación legal, etc.).
  - Área responsable.
  - Observaciones adicionales.
3. Haga clic en **Guardar Registro**.

#### Resultado esperado:

El sistema asigna automáticamente un folio único con formato CM-AAAA-NNNN (ejemplo: CM-2026-0001) y calcula el hash SHA-256 del registro para garantizar su integridad.

### Consultar la bitácora de auditoría

Disponible exclusivamente para Administradores del Sistema (Nivel 1).

#### Paso a paso:

1. Navegue a **Auditoría** → **Bitácora**.
2. Use los filtros disponibles para acotar la búsqueda por fecha, usuario, tipo de acción o resultado (ÉXITO / FALLO).
3. Cada entrada muestra: fecha y hora, usuario actor, acción ejecutada, recurso afectado, resultado y hash o huella criptográfica relacionada.

#### Resultado esperado:

La bitácora permite rastrear cualquier acción crítica. El registro es inmutable; no puede modificarse ni eliminarse desde la interfaz.

### Gestionar el estado de un colaborador

Disponible exclusivamente para Administradores del Sistema (Nivel 1).

Desde el detalle de un colaborador (**Gestión de Identidades** → **Colaboradores** → **seleccionar usuario**), el administrador puede ejecutar las siguientes acciones:

| Acción           | Cuándo usarla                                                           | Efecto en el sistema                                                                |
|------------------|-------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| Desactivar       | El colaborador está de vacaciones o baja temporal.                      | Estado → INACTIVO. No puede iniciar sesión. Certificado suspendido.                 |
| Revocar          | Incidente de seguridad, pérdida de credenciales o acceso no autorizado. | Estado → REVOCADO. Certificado invalidado permanentemente. Requiere nuevo registro. |
| Renovar vigencia | El periodo de vigencia está por expirar y el colaborador sigue activo.  | Se actualiza la fecha de expiración y se reactiva el certificado.                   |
| Reactivar        | Restablecer el acceso de un usuario desactivado temporalmente.          | Estado → ACTIVO. Certificado reactivado.                                            |

## Solución de Problemas

### Errores comunes y soluciones

| Error / Síntoma                             | Causa probable                                                      | Solución                                                                                                    |
|---------------------------------------------|---------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| 401 — Credenciales inválidas                | Contraseña incorrecta o usuario inactivo/revocado.                  | Verificar correo y contraseña. Si el usuario está inactivo, contactar al administrador.                     |
| 401 — Código TOTP incorrecto                | Código expirado (>30 s) o reloj del dispositivo desincronizado.     | Esperar al siguiente código. Si persiste, sincronizar la hora del teléfono en Configuración → Automática.   |
| 400 — Enlace de activación expirado         | Token expirado (>48 h) o ya fue utilizado.                          | Contactar al administrador para revocar el usuario y crear uno nuevo.                                       |
| 403 — Acceso denegado                       | El nivel de acceso del usuario no tiene permiso para esa operación. | Verificar con el administrador el nivel de acceso asignado.                                                 |
| 500 — Error al generar certificado de firma | FIELD_ENCRYPTION_KEY no configurado en el servidor.                 | El administrador técnico debe definir FIELD_ENCRYPTION_KEY en el .env del backend.                          |
| Sistema no envía correos de activación      | SMTP no configurado (modo demo activo).                             | Consultar enlaces desde /auth/demo/activation-links. Para correo real, configurar variables SMTP_* en .env. |
| Frontend no conecta con el backend          | VITE_API_URL apunta a una URL incorrecta.                           | Verificar frontend/.env y reiniciar el servidor con npm run dev.                                            |

### ¿Qué hacer si algo falla inesperadamente?

1. Tome nota del mensaje de error exacto que muestra la pantalla.
2. Anote la acción que realizaba cuando ocurrió el error.
3. Cierre sesión y vuelva a iniciarla para descartar problemas de sesión expirada.
4. Si el problema persiste, contacte al administrador técnico con la información del error.

## Preguntas Frecuentes (FAQ)

### ¿Por qué el sistema pide un código de teléfono cada vez que inicio sesión?

El sistema implementa autenticación de doble factor (2FA) obligatoria para proteger las cuentas, especialmente porque se maneja información sensible de personas en situación vulnerable. Este segundo factor impide que alguien que conozca su contraseña pueda acceder sin tener también su teléfono.

### ¿Qué pasa si pierdo mi teléfono con la aplicación autenticadora?

Contacte inmediatamente al administrador del sistema. El administrador puede revocar su secreto TOTP desde el panel de gestión de identidades, lo que le permitirá enrollar un nuevo dispositivo la próxima vez que intente iniciar sesión.

### ¿El sistema guarda las claves privadas de los documentos que firmo?

No. Las claves privadas ECDSA P-256 se generan y permanecen en su navegador mediante la Web Crypto API. El servidor nunca recibe ni almacena su clave privada. Solo se almacena el certificado público (.cer) y la firma resultante.

#### **¿Cómo sé si un registro de migrante ha sido alterado?**

Cada registro contiene un hash SHA-256 calculado al momento de su creación. La bitácora registra todos los cambios realizados, junto con la identidad del actor y la hora exacta. Un administrador puede verificar la integridad comparando el hash almacenado con el calculado sobre los datos actuales.

#### **¿Puedo usar el sistema desde mi teléfono celular?**

Sí. El sistema es una aplicación web accesible desde cualquier navegador moderno. Sin embargo, para operaciones se recomienda el uso de una computadora de escritorio o laptop.

#### **¿Qué significa el estado REVOCADO en un usuario?**

Un usuario revocado tiene su identidad digital permanentemente invalidada. A diferencia de un usuario desactivado (que puede reactivarse), la revocación es definitiva: el certificado queda marcado como revocado y el usuario no puede iniciar sesión. Si el colaborador regresa a la organización, deberá crearse un registro completamente nuevo.

#### **¿Mis datos personales están protegidos en el sistema?**

Sí. Los campos sensibles (nombre o alias, información de contacto) se almacenan cifrados mediante Fernet (AES-128-CBC + HMAC-SHA256). Las contraseñas se guardan como hash bcrypt y el secreto TOTP se almacena cifrado. La comunicación debe realizarse siempre por HTTPS en producción.

Repositorio del proyecto: [https://github.com/mirandacornejoa/Reto\\_CasaMonarca\\_Eq1\\_603](https://github.com/mirandacornejoa/Reto_CasaMonarca_Eq1_603)